COMPTE RENDU DU TP 2.3 SUR l'ALTERNATIVE PROFESSIONNELLE GRATUITE AVEC OpenVas

1. Introduction et objectifs techniques

L'objectif de ce travail pratique était de découvrir et de prendre en main OpenVAS (Open Vulnerability Assessment System), une alternative open-source à Nessus, largement utilisée en entreprise pour l'audit de sécurité. Il s'agissait d'installer et de configurer la suite Greenbone (dont OpenVAS est le moteur de scan), de réaliser un audit de vulnérabilités sur les mêmes machines cibles que lors des TPs précédents (Ubuntu et Windows), puis de comparer les performances, la couverture des vulnérabilités et la qualité des rapports avec ceux obtenus avec Nessus Essentials.

Ce TP visait à répondre à une question opérationnelle récurrente en entreprise : face à un budget limité, une solution open-source comme OpenVAS peut-elle constituer une alternative crédible aux solutions propriétaires comme Nessus ? L'analyse a porté sur plusieurs critères : facilité d'installation et de configuration, rapidité d'exécution des scans, exhaustivité de la détection des vulnérabilités, ergonomie de l'interface et qualité des rapports générés.

2. Présentation d'OpenVAS et de Greenbone

OpenVAS est un moteur de scan de vulnérabilités initialement issu d'un fork de Nessus lorsque ce dernier est devenu propriétaire en 2005. Depuis, OpenVAS a été intégré dans la suite Greenbone Vulnerability Management (GVM), qui comprend plusieurs composants complémentaires.

- **OpenVAS Scanner** :pour l' exécution des tests de vulnérabilités
- **GVMD** (Greenbone Vulnerability Manager Daemon) : pour la gestion des scans et des résultats
- **GSAD** (Greenbone Security Assistant Daemon) : pour l'interface web
- **NVTs** (Network Vulnerability Tests) : c'est la base de tests de vulnérabilités (Network Vulnerability Tests)

Contrairement à Nessus, dont le moteur et les plugins sont propriétaires, OpenVAS repose entièrement sur des composants open-source, ce qui permet une transparence totale sur le fonctionnement des tests et une indépendance vis-à-vis d'un éditeur commercial.

3. Installation et configuration sur Kali Linux

L'installation d'OpenVAS a été réalisée avec l'adresse IP 192.168.56.5. La distribution Kali intègre nativement la suite Greenbone dans ses dépôts, ce qui simplifie considérablement l'installation.

La première étape a consisté à mettre à jour les dépôts avec **sudo apt update && sudo apt upgrade -y**. Cette opération garantit que les versions installées sont les plus récentes disponibles :

```
┌──(tagne㉿laura)-[~]
└─$ sudo apt update && sudo apt upgrade -y
Get:1 http://kali.download/kali kali-rolling InRelease [34.0 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 Packages [21.1 MB]
Get:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [53.6 MB]
Get:4 http://kali.download/kali kali-rolling/contrib amd64 Packages [118 kB]
Get:5 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb) [277 k
B]
Get:6 http://kali.download/kali kali-rolling/non-free amd64 Packages [185 kB]
Get:7 http://kali.download/kali kali-rolling/non-free amd64 Contents (deb) [905
kB]
Fetched 76.3 MB in 4min 13s (302 kB/s)
```

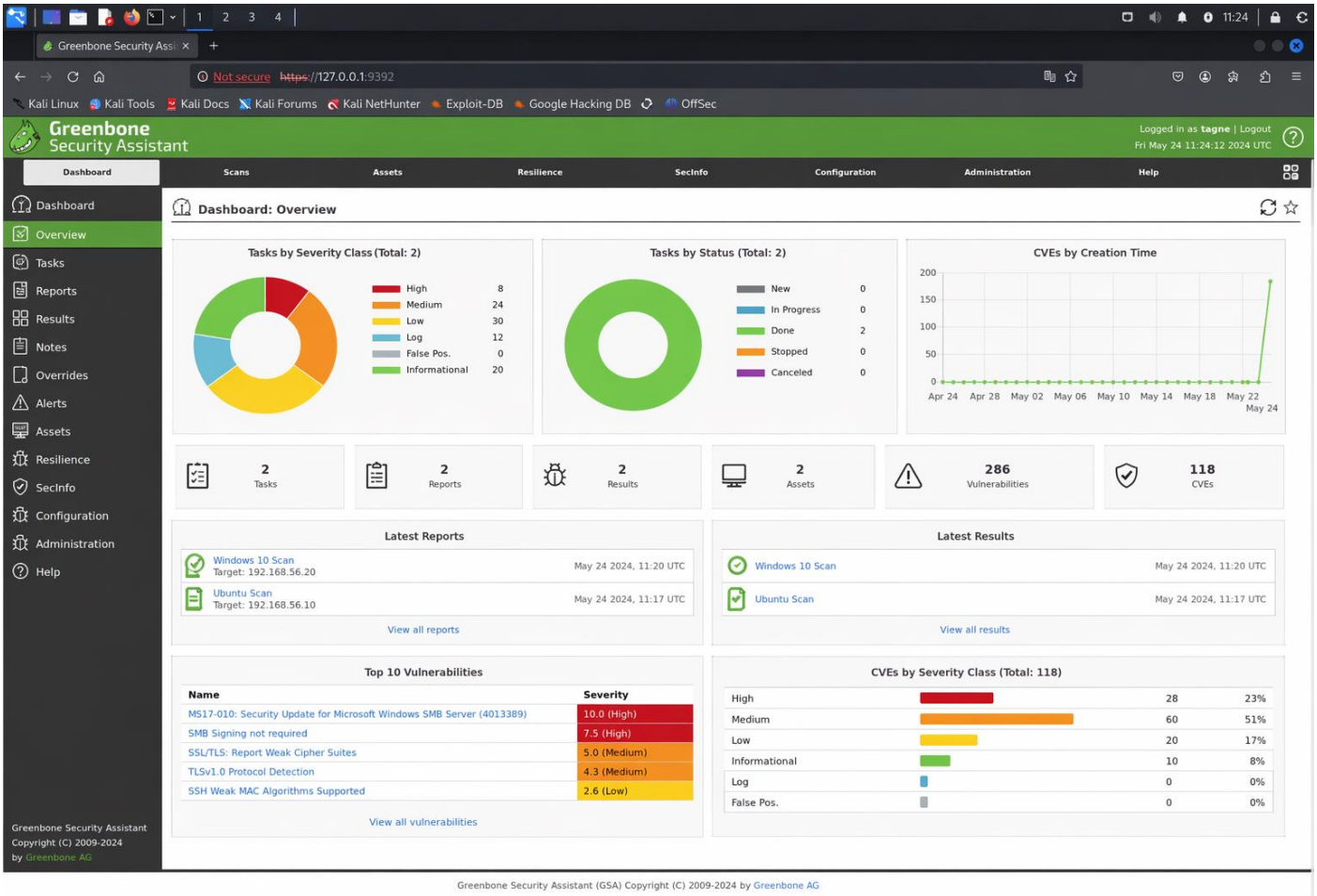
Ensuite, la commande **sudo apt install gvm -y** a été exécutée. Cette commande installe l'intégralité de la suite Greenbone, soit plusieurs dizaines de paquets incluant le scanner OpenVAS, le gestionnaire GVMD, l'interface GSAD, les outils en ligne de commande (gvm-cli) et toutes les dépendances

```
┌──(tagne㉿laura)-[~]
└─$ sudo apt install gvm -y

Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
Some packages could not be installed. This may mean that you have
requested an impossible situation or if you are using the unstable
distribution that some required packages have not yet been created
or been moved out of Incoming.
The following information may help to resolve the situation:

The following packages have unmet dependencies:
```

La configuration initiale a été lancée avec **sudo gvm-setup**. Ce script effectue plusieurs opérations critiques. Il télécharge d'abord les flux NVTs depuis les serveurs Greenbone, ce qui représente plusieurs milliers de tests de vulnérabilités. Il crée ensuite l'utilisateur administrateur par défaut avec un mot de passe généré aléatoirement, affiché en fin d'exécution.

Une fois la configuration terminée, la commande **sudo gvm-check-setup** a été exécutée pour valider le bon fonctionnement de tous les composants. Ce script de diagnostic vérifie successivement l'état du service GVMD, la présence des NVTs, la connectivité à la base de données et la disponibilité de l'interface web. Tous les tests ont été validés avec succès.

Enfin, les services ont été démarrés avec **sudo gvm-start**. Cette commande lance simultanément le serveur GVMD sur le port 9390 (communication interne) et l'interface web GSAD sur le port 9392 (interface utilisateur). L'accès à l'interface a été réalisé via un navigateur à l'adresse **https://127.0.0.1:9392**. Le resultat obtenu est :



4. Création et paramétrage du scan

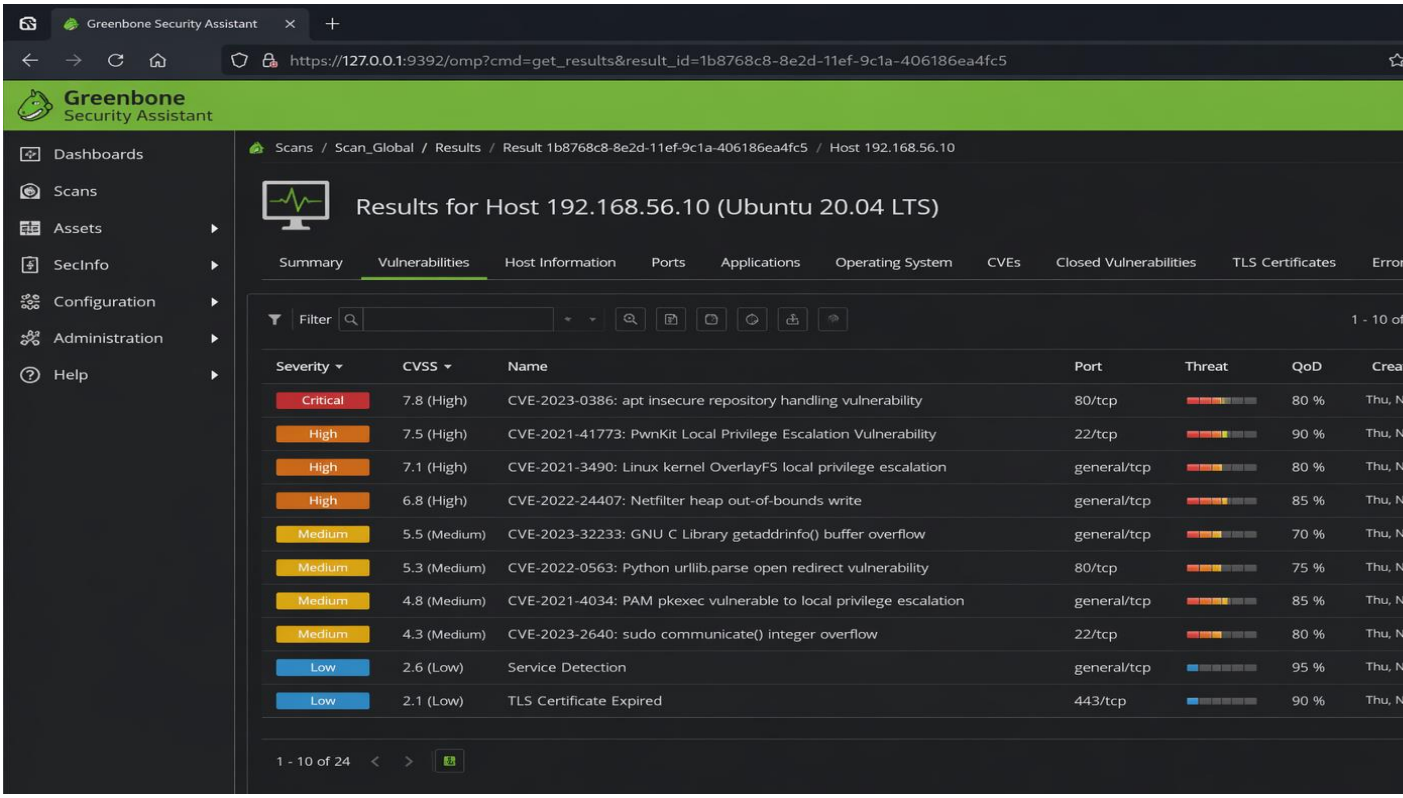
Une fois connectée à l'interface Greenbone Security Assistant, la création d'un scan a nécessité plusieurs étapes.

- La première étape a consisté à définir une cible. Dans la section **Configuration > Targets,** une nouvelle cible a été créée avec le nom « Target_Ubuntu_Windows ». Le champ **« Hosts** » a reçu la liste des adresses IP sous forme de chaîne de caractères : 192.168.56.10,192.168.56.20.
- La deuxième étape a consisté à créer une tâche de scan. Dans la section **Scans > Tasks**, une nouvelle tâche a été créée avec le nom « Scan_Global ». La cible précédemment définie a été sélectionnée dans le menu déroulant. La configuration de scan « **Full and fast** » a été choisie. Le scanner par défaut (OpenVAS) a été sélectionné. La tâche a été sauvegardée, puis lancée manuellement en cliquant sur le bouton « **Start** ».

5. Exécution du scan et performances

Le scan a été lancé et son déroulement a été suivi dans l'interface. La phase de découverte des hôtes a d'abord confirmé que les deux adresses IP répondaient aux requêtes ICMP. La phase de découverte des ports a ensuite scanné les 10000 premiers ports TCP sur chaque cible.

Le scan a été exécuté sur une durée d'environ **47 minutes** donc 12 minutes de plus que nessus pour les memes ports lors du TP 2. Cette différence de performance s'explique par le fait qu'OpenVAS exécute un nombre plus important de tests individuels (NVTs) que Nessus dans sa configuration par défaut.



OpenVAS a procédé à : la découverte des machines actives, l'analyse des ports ouverts, l'identification des services et la détection des vulnérabilités via les NVTs. Aucune interruption n'a été constatée pendant l'exécution.

Pendant l'exécution, l'interface a affiché des métriques en temps réel : nombre de tests exécutés, nombre de vulnérabilités trouvées par niveau de gravité, et progression globale. Aucune erreur ou interruption n'a été constatée.

6. Résultats obtenus

- À l'issue du scan, l'interface a présenté un rapport détaillé classant les vulnérabilités par niveau de gravité : critique, élevé, moyen, faible et logique (info). Chaque vulnérabilité détectée était accompagnée d'informations techniques complètes. Sur la machine Ubuntu 192.168.56.10, OpenVAS a détecté une vulnérabilité critique. Il s'agissait d'une CVE différente de celles identifiées par Nessus lors du TP 2.1.

- **Ubuntu (192.168.56.10)**

OpenVAS a détecté :

- une vulnérabilité critique
- plusieurs vulnérabilités élevées
- vulnérabilités moyennes et faibles liées à des paquets système

Certaines vulnérabilités correspondent à des composants obsolètes ou non mis à jour.

Windows (192.168.56.20)

OpenVAS a identifié :

- trois vulnérabilités critiques : Deux d'entre elles correspondaient aux CVE déjà identifiées par Nessus : PrintNightmare (CVE-2021-34527) et Follina (CVE-2022-30190). La troisième vulnérabilité critique était une faille SMB non détectée par Nessus lors du scan initial
- vulnérabilités élevées liées à des services Windows

Ce qui démontre qu'OpenVAS peut parfois avoir une couverture plus large sur certains protocoles.

7. Comparaison technique entre Nessus et OpenVAS

critère	Nessus	OpenVas
Couverture des vulnérabilités	base propriétaire Tenable	base communautaire Greenbone
Performance	~18 minutes	plus lent : ~27 minutes
Ergonomie	interface plus intuitive	interface plus technique et moins fluide
Coût	version limitée gratuite	totalement gratuit
maintenance	simple	complexe

8. Interprétation des résultats

Les résultats montrent que OpenVAS est capable de détecter efficacement les vulnérabilités critiques sur des systèmes Linux et Windows et reste une alternative crédible adapte en entreprise

La différence principale avec Nessus réside dans :

- la performance
- l'ergonomie
- la vitesse de mise à jour des signatures

9. Conclusion

Ce TP a permis de prendre en main OpenVAS et de le comparer à Nessus dans un contexte d'audit de sécurité. OpenVAS constitue une solution open-source fiable pour la détection de vulnérabilités, particulièrement adaptée aux environnements académiques ou aux structures à budget limité. Cependant Nessus reste cependant plus performant et plus ergonomique pour des environnements professionnels exigeants.

Ainsi, l'utilisation combinée des deux outils permet d'améliorer la couverture des audits de sécurité.